

עדימ תחטבא חוד

ריוואה ליח — 124 תסייט

3.0 הסרג

2026 רבמטפסב 3: קיראת

דבלב ימינפ שומישל — ידוס: גוויס

11 ללוק, 124 תסייט לש מדאה-חוכ לוחינ תייצקילפא לש עדימה תחטבא בצמ תא ראתמ הז רמסמ
App תפיכא: תללוק (3.0) תיחכונה הסרגה. סויה דעו טקיורפה תחיתפ זאמ ועצובש החשקה יבלש
תואשרה תדרפה מע Custom Claims יססובמ Firestore יללכ, Firestore i-Authentication לע Check
הכר היצרגים מע תורפס ל-6 PIN גורדשו, Firestore-ב תגרודמ הליענ מע תרשה דצב PIN תומיא

סיניינע נכות

- מילהנמ ריצקת.
- סויאה לדומ.
- הנגהה תובכש — החטבא תרוטקטיכרא.
- החשקה יבלש 11 — נמזה ריצ.
- סיבלש מוכיס — יחכונ בצמ.
- תואצות — RED TEAM Assessment.
- תורפס 6 (PIN) נכדועמ סויא לדומ.
- מוכיס — היסרגר תוקידב.
- תונווכמ רצומ תוטלחה.
- ךשמהל תוצלמה.

סילהנמ ריצקת 1.

עדימה. (מילכ, מיבכר, מיצוביש, תוכמסה, הדיל יכיראת, תומש) סדא-חוכ לזהינל PWA איה 124 תסייט תייצקילפא דבלב טנרטיא רתא ררד שיגנו Firebase Firestore ב נסחואמ

ויה הסינכבש מידוקה. תומיא לכ אלל, חותפה טנרטיאהמ קיחמו אירק היה דסמה: (החשקהה ינפל) יתלחתה בצמ דבלב חוקלה דצב תזורחמ תאוושה

App Check (רוקמ חיכות), Firebase Auth (תובכש 4-ב וגומ דסמה. ועצוב החשקה יבלש 11: 3.0 הסרג) יחכונ בצמ סע תרשב פכאנ ישיא PIN. (תרשב לכה סיפכוא) Firestore Rules, Custom Claims (האשרה חיכומ), (תוהז חיכומ) (סיפוריצ ויילימ) תורפס 6-7 גרדושמו, תגרודמ הליענ

ללזכ סוטטס	תויטירק תויועיגפ	RED TEAM	היסרגר תוקידב
✓ PRODUCTION READY	0	✓ 11/11	✓ תורבוע +143

סוּיָאָה לָדוּם

תובכש 2 — תומיאה לדומ

לע App Check י"ע וגומ. Firebase Auth. ןובשח רצוי. ישארה הסינכה רעש: (תורפס 4) תרגסמ דוק — 1 הבכש תגרודמ הסינכ-תליענו (יטמוטוא brute-force םסוח) Authentication. תגרודמ הליענ םע (Cloud Function) תרשה דצב ףכאנ. שמתשמ לכל תישיא הליענ: (תורפס 6) ישיא PIN — 2 הבכש. יארקא חלמ + תויצרטיא 210,000 םע PBKDF2 Hash: Firestore. ב-

סוטטסו הפיקת ירוטקו

רוטקו	הנגה	סוטטס
(list) תינומה הביאש	Firestore Rules: list: if false	מוסח ✓
תומיא אלל השיג	App Check + Auth + authorized claim	מוסח ✓
רוקמהמ מידוק תאירק — F12	(6 בלש) רוקמהמ ואצוה מידוק	מוסח ✓
האלמ השיג ← ימינונא תומיא	Custom Claims: authorized:true (7 בלש)	מוסח ✓
(דקפמ → לייח) תואשרה תמרה	role claim + isSensitiveDoc דצ-תרש (8 בלש)	מוסח ✓
brute-force דוק	App Check לע Auth (ב1 בלש)	מוסח ✓
brute-force PIN	(10 בלש) rate limiting + דצ-תרש הליענ	מוסח ✓
ןמדזמ PIN שוחינ	(11 בלש) 1:1,000,000 = תורפס 6	חשקומ ✓
DevTools bypass PIN	(10 בלש) דצ-תרש תומיא	מוסח ✓
shoulder surfing	רתוי השק — (11 בלש) תורפס 6	ותוממ ⚠

הנגהה תובכש — החטבא תרוטקטיכרא 3.

הבכש 1: App Check reCAPTCHA v3	לעו Firestore ל'ע ףוכא .טפירקסמ אל ,יתימאה רתאהמ העיגמ השקבהש חיכומ Authentication.
הבכש 2: Firebase Authentication Email/Password	קיפסמ אל ודבל ימינוגא תומיא .המסיסה אוה דוקה — u@sq124.app ונבשח
הבכש 3: Custom Claims authorized + role	שרדנ דקפמ=role .תרשה דצב ונבשחל תויגת הדימצמ Cloud Function markAuthorized משיגר מיכמסמל
הבכש 4: Firestore Rules תבחרומ 3 הסרג	יכמסמ .מוסח list(). isAuthorized() + isSensitiveDoc() + isPrivileged(). מינוגמ admin/authprofile/push_tokens/login_lock
ישיא הבכש 5: PIN PBKDF2 + דצ-תרש	ימוקמ fallback-Firestore, ב-תגרודמ הליענ ,תויצרטיא 210K ,תורפס 6

החשקה יבלש 11 — נמזה ריצ 4.

בלש	מש	רואית
1 בלש	Firestore לע App Check תפיכא	ניקת reCAPTCHA נקוט תבייח השקב לכ. תינוציח השיגמ דסמה תריגס.
11 בלש	לע App Check תפיכא Authentication	100% Verified. תרשה תמרב הסינכ ידוק לע brute-force תמיסח
2 בלש	Firestore יללכ תסירפ	תינוציח הקיחמ תמיסח, list תמיסח, תומיא תבוח
3 בלש	+ Firebase Auth ימינונא תומיא תלעפה	(ףקת שמתשמ) "ימ" חיכומ — תיסיסב תומיא תבכש
4 בלש	תורגסמ תדרפה	םמצע תסייטה ישנאמ וניא ששחה — הנווכב החדנו לקשנ
5 בלש	PIN ישיא (חוקל דצ)	SHA-256 + חלמ → PBKDF2 210K. שמתשמ לכל תישיא הליענ
6 בלש	רוקמהמ מידוק תאצוה	u@sq124.app:תרש-תססובמ הסינכ
7 בלש	ימינונא תומיא תצרפ תריגס	Custom Claims: authorized:true קר
8 בלש	דיקפת יפל תואשרה תלבגה	role claim + isSensitiveDoc —
9 בלש	RED TEAM Assessment	11/11 ומסחנ F1 Critical נקות. רוטלומיסב הפקתה ישיחרת
10 בלש	תרשה דצב PIN תומיא	Cloud Function + תגרודמ הליענ + Firestore. DevTools bypass מוסח
11 בלש	תורפס 6-7 PIN גורדש	םיפוריצ ויילימ. הפיכא → הרהזא → רנאב:הכר היצרגימ

מיבלש מוכיס — יחכונ בצמ 5.

תורעה	סוטטס	ביכר
1 בלש זאמ ליעפ	פוכא ✓	App Check — Firestore
100% Verified (3.7K/3.7K)	פוכא ✓	App Check — Authentication
isAuthorized + isSensitiveDoc + isPrivileged	ליעפ ✓	Firestore Rules v3
markAuthorized י"ע מעמטומ authorized:true + role	ליעפ ✓	Custom Claims
F12-ב דוק ויא, תרש-תססובמ הסינכ	משוימ ✓	רוקמל קוחמ מידוק
Cloud Function + Firestore הליענ	ליעפ ✓	PIN — ישיא דצ-תרש
תגרודמ הפיכא מע הכר היצרגימ	ליעפ ✓	PIN — 6 תורפס
ומסחנ הפקתהה ישיחרת לכ	11/11 ✓	RED TEAM
חוקלל Cloud Function, allow write: false	ליעפ ✓	Audit Log
המוסח חוקל תאירק, מימשרנ הסינכ תונולשכ	ליעפ ✓	Auth Events

6. RED TEAM Assessment — תוצאות

Firestore רוטלומיסב מיימניד הפקתה שיחרת 11 — RED TEAM assault testing ךרד הפיקמ הכרעה העצוב
מינוש תומיא ירשקה 8 םע, Emulator

#	שיחרת	הנגה	האצות
1	(האירק) תימינונא השיג	isAuthorized()	✓ BLOCKED
2	(הביתכ) תימינונא השיג	isAuthorized()	✓ BLOCKED
3	authorized אלל תמואמ	authorized claim	✓ BLOCKED
4	authprofile-ל בתוכ לייח	isPrivileged + isSensitiveDoc	✓ BLOCKED
5	ודיקפת הנשמ לייח	isPrivileged בUpdate	✓ BLOCKED
6	admin-ל בתוכ לייח	isSensitiveDoc	✓ BLOCKED
7	push_tokens הנשמ לייח	isSensitiveDoc + isPrivileged	✓ BLOCKED
8	authprofile קחומ לייח	isPrivileged בDelete	✓ BLOCKED
9	authorized:false	authorized==true	✓ BLOCKED
10	LIST query	list: if false	✓ BLOCKED
11	Role spoofing	Server-side claims	✓ BLOCKED

הכרעהב ונקותש מיאצממ

הרמוח	רואית	ונקית	סוטטס
F1 (CRITICAL)	השרומ אל שמתשמ תריצי	מייק authprofile קדוב markAuthorized	✓ נקות
push_tokens DoS (MEDIUM)	תוארתה ינקוט הנשמ לייח	push_tokens ל- isSensitiveDoc ףסונ	✓ נקות

תורפס 6 PIN — נכדועמ מוֹיא לדומ

רוטקו לכ לע העפשהה. 100:מ-10,000 ל-1,000,000 יפ מפוריצה בחרמ תא ליפכמ תורפס 6 ל-4 מ-PIN-ה גורדש הפיקת:

רופיש	(תורפס 6) ירחא	(תורפס 4) ינפל	רוטקו
x100	1:1,000,000	1:10,000	נמדזמ שוחינ
יוניש אלל	5 ירחא מוסח	5 ירחא מוסח	Brute-force (הליענ סע)
יתועמשמ	רתוי השק	תיסחי לק	Shoulder surfing
יוניש אלל	(10 בלש) מוסח	(10 בלש) מוסח	DevTools bypass

הכרה היצרגימה תייגטרטסא

תוגהנתה	יאנת	המר
ךכ רחא/נכדע + "גרדשל קלמומ": בהז רנאב	תורפס 4 = יחכונ PIN	ליגר רנאב
נימו ונידע ךכ רחא. "מימי 7 חות שרדנ ונכדע"	תויחד 3+	הרהזא
תוקתנתה = לוטיב. יזכרמ לדומ	מימי 7 + תויחד 3+	הפיכא

מיינכט מיטרפ

- שמתשמ לכל יארקא חלמ + תויצרטיא 210,000 סע Hash: PBKDF2
- Cloud Function verifyPersonalPin — תרשה דצב hash הוושמ
 - תוקד 10 מומיסקמ, $30s \times 2^{(rounds-1)}$ → תונויסינ 5: תגרודמ הליענ
- המיסח אל, 5 בלש תחטבאל הדירי — הנימו אל CF מא ימוקמ Fallback
- acceptedPinFormat: (backward compat) הסינכל תורפס 6 וא 4 לבקמ
 - validPinFormat: שרוד 6 קידב שרוד
- רפוס קר, מסוח אל — שמתשמ מִש יפל localStorage-ב תויחד בקעמ

מוכיס — היסרגר תוקידב 8.

החטבאה תובכש לכ תא תוסכמ תוקידבה. תורבוע ולוכ, Playwright תוקידב +143

הקידב ץבוק	רואית	סוטטס
pin_upgrade_test.mjs	מישיחרת 7 — PIN תנפצה תחשקה	✓
pin_upgrade_migration_test.mjs	מישיחרת 9 — תורפס 6-ל היצרגים	✓
pin_race_test.mjs	סרדנ אל PIN — הביתכ יצורמ	✓
red_team_firestore_rules_test.mjs	RED TEAM ישיחרת 11	✓
firestore_rules_test.mjs	מישיחרת 20+ — Firestore יללכ	✓
qa_env_skip_test.mjs	הליפנכ רפסנ אל הביבס לשכ	✓

(ימוי חוד) מייטמוטוא מיקרוס

קרוס	רואית	סוטטס
scan_security.mjs	XSS, injection, secrets — החטבא תקירס	✓
scan_quality.mjs	דוק יעוציבו תוניקת	✓
scan_ux.mjs	רואית אללל מירותפכ, רושיא ילב הקיחמ — שמתשמ תייווח	✓

9. תונוכמ רצומ תוטלחה

תרשב תורגסמ תדרפה ויא	סיר'ציפ תרבוש התייה האלמ הדרפה. ׁמצע תסייטה ישנאמ וניא ששחה :התחדנו הלקשנ (תוריקס, תומש תמלשה, תויונרות חול) תרגסמ-יצוח
תורפס 4 ראשנ תרגסמ דוק	הליענ + (םימרוג ינש) PIN + דוקה. יטמוטוא brute-force ׁסוח Auth לע App Check הרומת אלל ׁוכיח הפיסומ הכראה. קיפסמ ׁיקזח = תגרודמ
ההכ בצמ ויא	סומיסקמ 480px, תירבע RTL, טסריפ-לייבומ היצקילפאה. בוציע תטלחה
המיסח אל, הכר היצרגים — PIN תידיים	(םימי 7 + תויחד 3) תגרודמ הפיכא + הרהזא + רנאב. הקלח שמתשמ תייווחל תופידע שמתשמ ׁא עיתפהל ילב קיפסמ ׁמז ׁינתונ

רשמהל תוצלמה 10.

תופידע	הצלמה	תורעה
החובג	מינכדועמ Firestore יללכ מסרפל	הסירפל הנכומ — (8 בלש) תבחרומ 3 הסרג
החובג	Cloud Functions סורפל (10 בלש)	verifyPersonalPin + login_lock_
תינויב	PIN תייצרגימ רחא בקעמ	שדוח חות תורפס 6-7 וגרדש +80%-ש אדוול
תינויב	(weeklyBackup) יעובש יוביג	ליעפ Cloud Scheduler יוביגש אדוול
הכומנ	חורא ירמונאפלא דוק	App Check מע חוד אל — שרדנ מא ירשפא
הכומנ	תירוזחמ תרוקיב	נועברל תחא RED TEAM חוד

תובכש 4-ב וגומ דסמה. מיפיקמ החשקה יבלש 11 הרבע 124 תסייט תייצקילפא :מוכיס
ה-RED TEAM ישיחרת לכו, תגרודמ הליענו תורפס 6 מע תרשב פכאנ ישיא PIN, דצ-תרש
רוצייל הנכומ תכרעמה. החלצהב ומסחנ

— חודה חוס —